

CHALLENGE

SpeedRunners



CHALLENGE ANY%

- **MISSÃO: BLINDAR O CHALLENGE DA FORD**
- **DIFICULDADE: SIM**
- **OBJETIVO: 100 PONTOS DE SECURITY**
- **IMPEDIMENTO: BLUE TEAM**

CONTEÚDO

- **AS PRIMEIRAS SPLITS**
- **O CRACHÁ DE ACESSO**
- **A BLINDAGEM**
- **O COFRE**
- **A CAIXA PRETA**

AS PRIMEIRAS SPLITS

VALIDAÇÃO VS SANITIZAÇÃO

`<SCRIPT>ALERT('XSS')</SCRIPT>@HACKERDASILVA.COM`

VALIDAÇÃO



SANITIZAÇÃO



VALIDAÇÃO 101

- **O QUE VALIDAR?**
 - **TIPAGEM - ESTÁ ESCRITO DE FORMA CORRETA?**
 - **PRESENÇA - EXISTE O CARACTERE OBRIGATÓRIO "X"?**
 - **TAMANHO - O TAMANHO É REAL?**
- **CAMPOS: E-MAIL, MARCA, MODELO, VERSÃO...**



SANITIZAÇÃO 101

SQLI

XSS

- O QUE VALIDAR?
 - CARACTERES ESPECIAIS (ESCAPAR CARACTERES)
 - ' - SQLI
 - <SCRIPT> - XSS
- A REGRA DO JOGO: "NUNCA CONFIE NO QUE VEM DO TECLADO DO USUÁRIO!"

NORMALIZAÇÃO DE API

- `f0rD == FORD == ford == forD == Ford == f0rd (...)`
- **UTILIZEM ENUMS PARA MARCA E MODELO!**
 - **CLASSES MODELO COM RESPOSTAS FIXAS!**
- **NORMALIZAÇÃO É CHAVE PARA O DESAFIO 1**



BUFFER OVERFLOW & FLOODING

BUFFER OVERFLOW

AAAAAAAAAAAAAAAAACOMANDO_PICA




CÓDIGO

11



VS

FLOODING

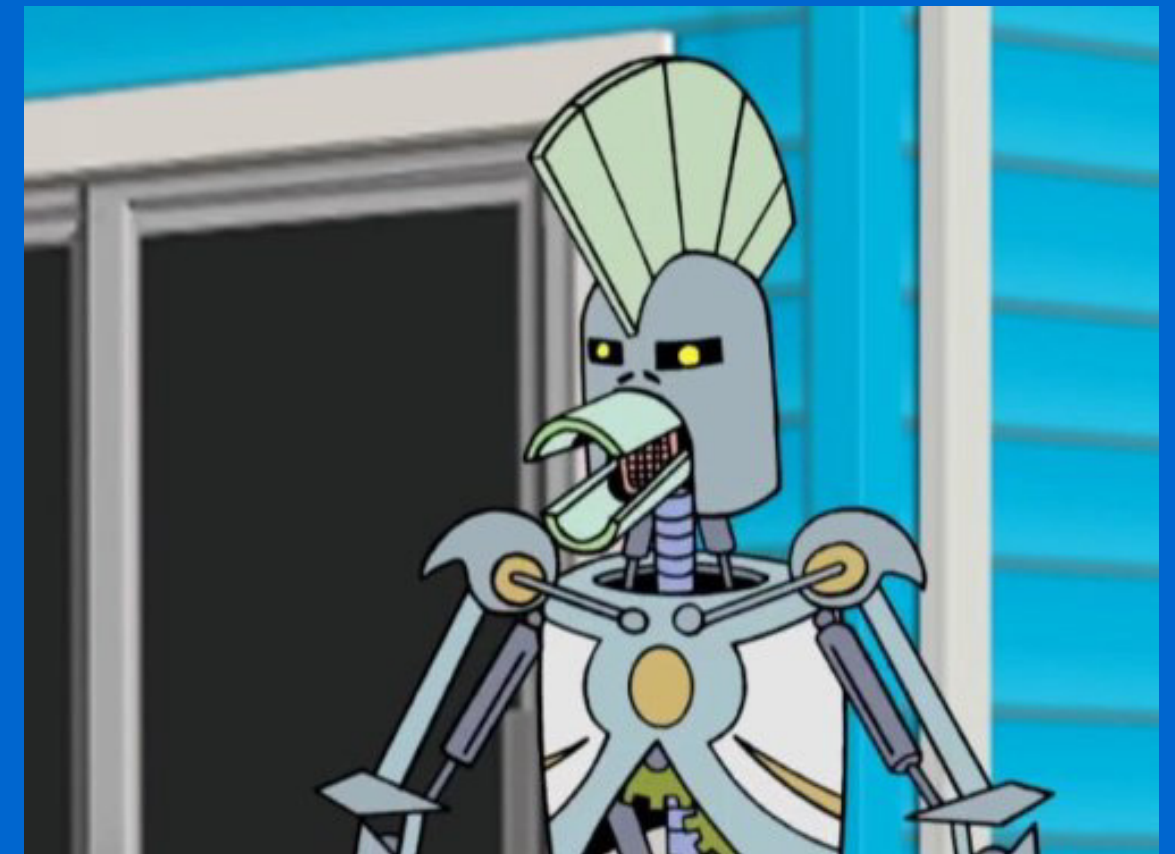
The diagram shows a memory buffer represented as a horizontal bar. The bar is divided into two sections: 'BUFFER' on the left and 'CODIGO' on the right. The 'BUFFER' section is filled with 'A's, and the 'CODIGO' section is filled with 'B's. An arrow points to the end of the 'BUFFER' section, indicating the point of overflow.

NOOOOSSA

[illegible]

TRATAMENTO SEGURO DE ERROS

- ERRO 500 -> INTERNAL SERVER ERROR (TRANQUILIDADE)
- ERRO 500 -> SQL QUERY FAILED (KKKKKKKKKKKKKKKKKKKK)
- ESCONDA STACK TRACES E TECNOLOGIAS



O CRACHÁ DE ACESSO

JWT

- **JSON WEB TOKEN**
- **HEADER: ALGORITMO**
- **PAYLOAD: DADOS (SEM SECRET!!!!!!)**
- **SIGNATURE: SELO DE AUTENTICIDADE**



OAUTH2 & BEARER TOKENS

- **BEABER: O "DONO" DO "PODER"**
 - **AUTHORIZATION HEADER: BEARER <TOKEN>**
- **EXPIRAÇÃO DO TOKEN É OBRIGATÓRIA**
- **IMPEDE ALTERAÇÃO SEM AUTENTICAÇÃO**
- **FACILITA O CONTROLE DE ACESSO**

RBAC

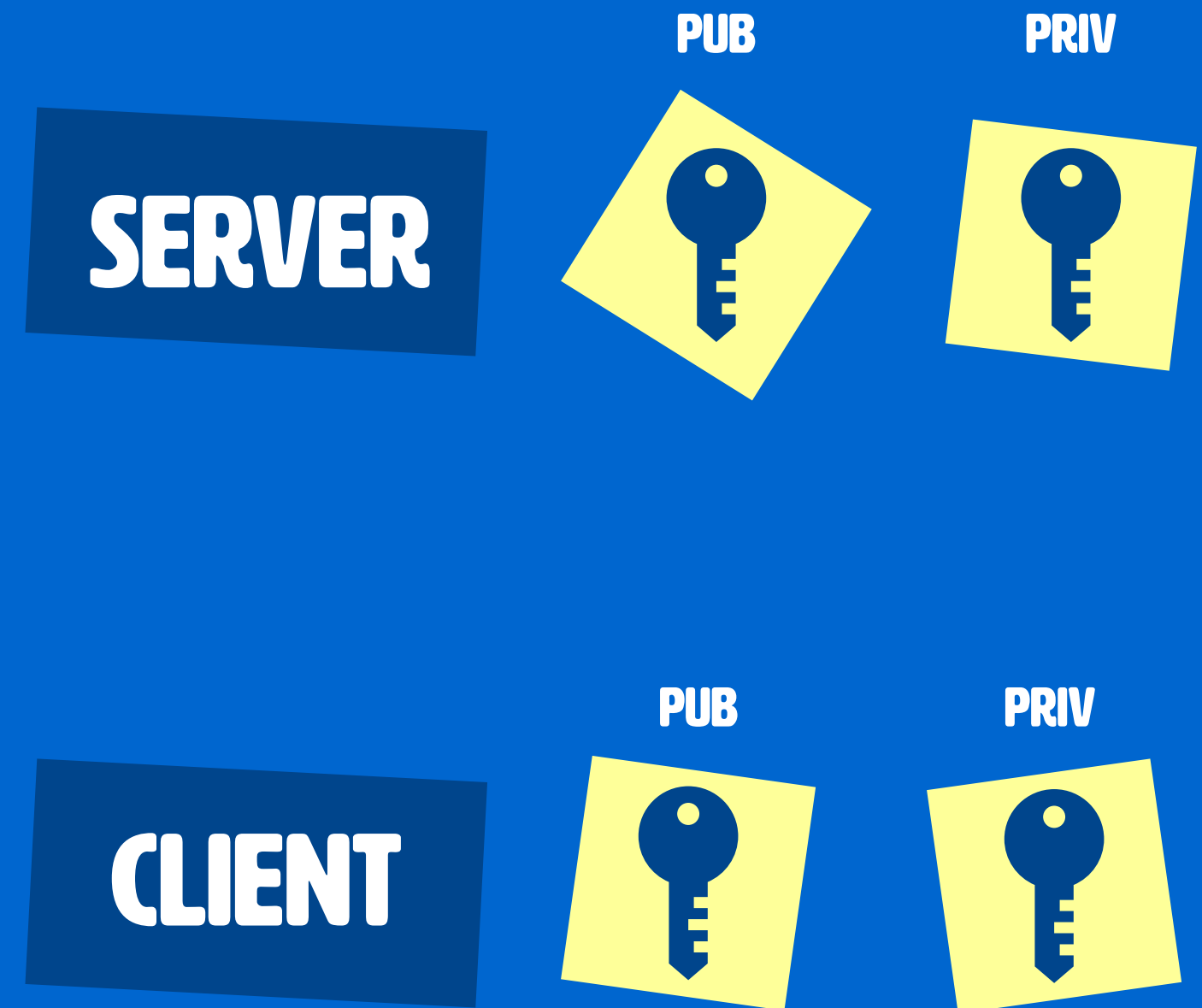
- **ROLE BASED ACCESS CONTROL**
- **ADMIN: CONFIGURAÇÕES GLOBAIS**
- **ANALISTA (FORD): LEADS E DASHBOARD**
- **USER: DADOS PESSOAIS (UNITÁRIO)**



A BLINDAGEM (DA RANGER?)

HTTP VS HTTPS

- TLS 1.2 -> TÚNEL
- CRIPTOGRAFIA ASSIMÉTRICA
 - PÚBLICA
 - PRIVADA
- SEM HTTPS = SNIFFING DE DADOS



IDEMPOTENCY KEYS

- **RATE LIMITING: EVITA DENIAL OF SERVICE E ATAQUES REPETITIVOS**
- **IDEMPOTENCY KEY: GARANTE QUE O CLIQUE DUPLO NÃO CRIE 2 LEADS**
- **REQUISIÇÃO DEVE SER ASSINADA COM UM TOKEN ÚNICO**
 - **MUITOS TOKENS DE UMA PESSOA = BLOCK**
 - **TOKEN DUPLO = APENAS UM É REALIZADO**

"CORS" CORRETO

- **CROSS-ORIGIN RESOURCE SHARING**
- **ACCESS-CONTROL-ALLOW-ORIGIN**
- **NUNCA USE ***
- **ALLOW ***
- **BÔNUS: NUNCA USE "IMPORT X" NO PYTHON**
 - **É FEIO E IMPRÁTICO E RUIM E TOSCO E DESAJEITADO E PAIA E ZOADO E PÉSSIMO E ESQUISITO E FEIO**

O COFRE

CRIPTOGRAFIA EM REPOUSO

- **DADO NO DB != DADO LEGÍVEL**
- **AES-256 PARA DADOS SENSÍVEIS**
- **BCRYPT PARA SENHAS**
- **NÃO UTILIZE CRIPTOGRAFIAS "RESOLVIDAS" (DES E MD5)**



RETENÇÃO E DESCARTE

- DADO GUARDADO = RISCO GUARDADO
- POLÍTICA DE RETENÇÃO (LGPD)
- ANONIMIZAÇÃO VS DELEÇÃO FÍSICA
- O QUE É ANONIMIZAÇÃO?

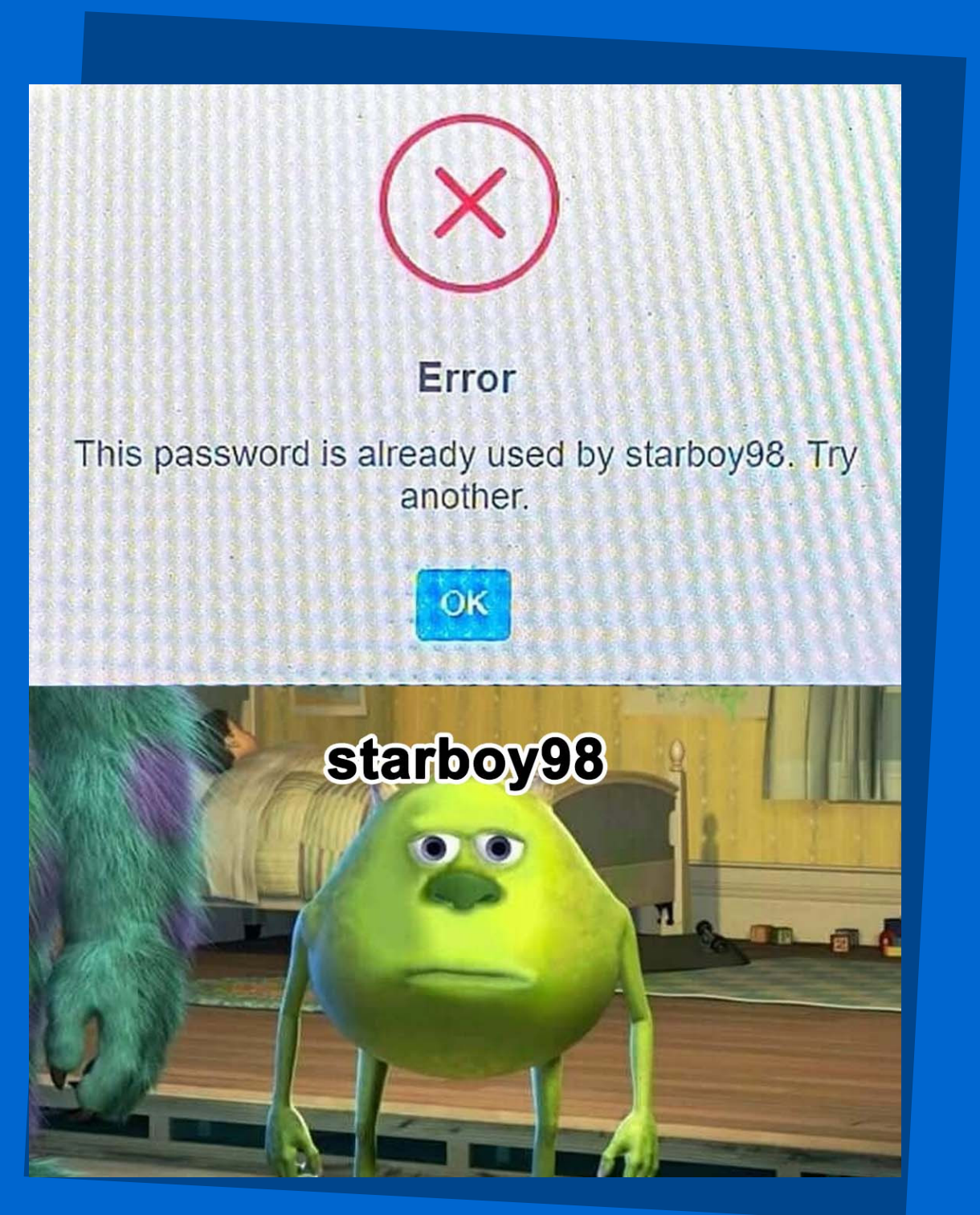


PSEUDOANONIMIZAÇÃO

- ANONIMIZAR É IRREVERSÍVEL
- PSEUDO - DERIVADO DO GREGO PSEUDÉS (ψευδής)
- TROCAR O NOME POR ID OU SEPARAR TABELAS E GUARDAR A JUNCTION TABLE
- REVERSÍVEL ATRAVÉS DE CHAVES, CÓDIGOS OU INFORMAÇÃO EXTERNA
- BOM PARA SE UTILIZAR EM ML E DASHBOARDS (VIN SHARE)

EXPOSIÇÃO ACIDENTAL

- CUIDADO COM O .ENV
- LOGS QUE GRAVAM SENHAS
- ENDPOINTS DE TESTE ESQUECIDOS
- LOGS QUE PRESERVAM A STACK / "VISÃO DO DEV"



A CAIXA PRETA

LOGGING ESTRUTURADO

- LOGS EM JSON (WINSTON/PINO)
- RASTREABILIDADE (TRACE ID)
- "QUEM FEZ O QUÊ, QUANDO E ONDE?"



MONITORAMENTO DE EVENTOS

- DASHBOARDS DE ERROS 5XX - ERROS DO SERVIDOR
- ALERTAS DE BRUTE FORCE
- IDENTIFICAÇÃO DE COMPORTAMENTO SUSPEITO
- HONEY POTS
- AUDIT TRAIL PARA AÇÕES CRÍTICAS



GGWP!

ACHIEVMENT UNLOCKED!

- **RESULTADO DA MISSÃO: SUCESSO!**
- **STATUS FORD: SAFE DO SAFE**
- **STATUS PROJETO: PROTEGIDO CONTRA SCRIPT KIDDIES E BOTS**